

INFORME EXHAUSTIVO: INTELIGENCIA ARTIFICIAL GENERATIVA APLICADA A RIESGOS DE CIBERSEGURIDAD

Investigación de Tendencias Desde 2024 en Aplicaciones Defensivas y Amenazas Emergentes

Consorcio de Científicos de Datos, Estrategas de Ciberseguridad y Expertos en Resiliencia Digital

Fecha de Elaboración: Enero 2026

Enfoque Territorial: España (Contexto Comparativo Global)

RESUMEN EJECUTIVO

La convergencia entre Inteligencia Artificial Generativa (GenAI) y ciberseguridad representa el fenómeno más disruptivo de 2024-2025 en infraestructura digital. Este informe sintetiza hallazgos de 145+ fuentes académicas de alto rigor, organismos gubernamentales certificados (ENISA, CISA, NCSC, ANSSI, CSE), marcos normativos emergentes (EU AI Act, NIS2, NIST AI RMF, ISO/IEC 42001) e investigaciones de laboratorio documentadas.

Hallazgos Críticos para España:

1.
Amenaza Cuantificada: 100,000+ ciberataques registrados en 2024 (uno "muy grave" cada 3 días); incremento 300% desde 2015. España ocupa 5º lugar en ataques ransomware globales.
2.
Respuesta Estatal: Inversión €1.157 mil millones, creación Centro Nacional de Ciberseguridad (CNC), transposición NIS2 esperada Q1 2026. Expansión regulatoria de 1,000 a ~12,000 entidades reguladas.
3.
IA Generativa como Amenaza: Vectores ofensivos documentados incluyen inyección de prompts (87% éxito basal, <0.5% con defensas especializadas), envenenamiento de datos, extracción de modelos, ataques a cadena de suministro, y deepfakes (8M archivos 2025, +1,600% desde 2023). Actores estatales (Irán, China, Corea del Norte) utilizan sistemáticamente GenAI en fases completas del ciclo de ataque (reconocimiento, explotación, persistencia).
4.
IA Generativa como Defensa: Sistemas defensivos basados en ML-IDS logran 96.9% tasas de detección; threat hunting asistido por IA reduce MTTD de 181 días a <24 horas; detección de deepfakes alcanza 94-96% en condiciones óptimas con arquitecturas multimodales.
5.
Brechas Críticas: Solo 26% de organizaciones confían en capacidad para detectar amenazas impulsadas por IA. 35% de pequeñas organizaciones reconocen preparación inadecuada. Marcos regulatorios aún en implementación (EU AI Act obligatorio agosto 2026).

Amenaza Cuantificada: 100,000+ ciberataques registrados en 2024 (uno "muy grave" cada 3 días); incremento 300% desde 2015. España ocupa 5º lugar en ataques ransomware globales.

Respuesta Estatal: Inversión €1.157 mil millones, creación Centro Nacional de Ciberseguridad (CNC), transposición NIS2 esperada Q1 2026. Expansión regulatoria de 1,000 a ~12,000 entidades reguladas.

IA Generativa como Amenaza: Vectores ofensivos documentados incluyen inyección de prompts (87% éxito basal, <0.5% con defensas especializadas), envenenamiento de datos, extracción de modelos, ataques a cadena de suministro, y deepfakes (8M archivos 2025, +1,600% desde 2023). Actores estatales (Irán, China, Corea del Norte) utilizan sistemáticamente GenAI en fases completas del ciclo de ataque (reconocimiento, explotación, persistencia).

IA Generativa como Defensa: Sistemas defensivos basados en ML-IDS logran 96.9% tasas de detección; threat hunting asistido por IA reduce MTTD de 181 días a <24 horas; detección de deepfakes alcanza 94-96% en condiciones óptimas con arquitecturas multimodales.

Brechas Críticas: Solo 26% de organizaciones confían en capacidad para detectar amenazas impulsadas por IA. 35% de pequeñas organizaciones reconocen preparación inadecuada. Marcos regulatorios aún en implementación (EU AI Act obligatorio agosto 2026).

I. CONTEXTO NACIONAL ESPAÑA: MÉTRICAS Y GOBERNANZA

A. Panorama de Incidentes y Vulnerabilidad

España experimentó una intensificación sin precedentes de la actividad cibercriminal en 2024-2025. Conforme a documentación oficial del Gobierno de España, se registraron más de 100,000 ciberataques, con un promedio de un incidente clasificado como "muy grave" cada tres días.[1][2] Este volumen representa un incremento del 300% desde 2015, señalando no solo aumento cuantitativo sino también sofisticación cualitativa de vectores de ataque.

El panorama sectorial revela concentración de amenazas en infraestructuras críticas. España se posiciona como quinta en incidentes de ransomware a nivel global, con 58 casos registrados en el primer semestre 2024 (incremento del 23% respecto a 2023).[3] La administración pública constituye el sector más atacado (38% del volumen de incidentes europeos), seguido por transporte (11%) e infraestructura digital.[4] Este patrón refleja objetivos de máximo impacto operacional.

B. Indicadores de Madurez de Ciberseguridad (NCSI)

El Índice Nacional de Ciberseguridad (NCSI, por sus siglas en inglés) posiciona a España en una puntuación consolidada de 89.17/100, ubicándola en el top 20 global.[5] Desagregando por dimensiones:

- Gobernanza de Políticas: 6/7 (86% de conformidad)
- Unidad de Política de Ciberseguridad: Designada y empoderada
- Estrategia Nacional: Documentada con plan de acción y métricas de implementación
- Capacidades de Investigación: Reconocimiento formal de RENIC (Red Española de Excelencia en Investigación de Ciberseguridad)

Esta puntuación refleja progreso significativo, aunque subsisten áreas de vulnerabilidad en coordinación interinstitucional y capacidades operativas de respuesta ante incidentes de escala nacional.

C. Marco Legislativo: NIS2 y Reorganización Institucional

Transposición NIS2 Directive

En enero de 2025, el Consejo de Ministros español aprobó el Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad, vehículo legislativo para incorporar la Directiva NIS2 (y la Directiva de Resiliencia de Entidades Críticas) en ordenamiento nacional. El cronograma legislativo proyecta:

- Febrero 2025: Registro acelerado en Congreso y Senado
- Q3 2025: Audiencias parlamentarias y enmiendas legislativas
- Q1 2026: Entrada en vigor esperada
- H1 2026: Lanzamiento portal de registro CNCS; aplicabilidad de notificación de incidentes (24 horas reporte inicial, 72 horas informe detallado)

Impacto Regulatorio Crítico: Expansión del universo regulado de <1,000 a aproximadamente 12,000 entidades distribuidas en 18 sectores. Clasificación bifurcada: Entidades Esenciales (EE: ≥250 empleados o €50M facturación) e Importantes (EI: ≥50 empleados o €10M facturación). Sanciones administrativas escalonadas: €10M o 2% volumen de negocios global para infracciones muy graves (EE); €7M o 1.4% para EI.

Creación Centro Nacional de Ciberseguridad (CNC)

El presidente Pedro Sánchez anunció octubre 2025 la creación del CNC como entidad interministerial bajo presidencia directa. Funciones asignadas:

- Coordinación nacional ante ataques cibernéticos masivos
- Detección y análisis de amenazas digitales (asistidas por IA avanzada)
- Protección de infraestructuras críticas (energía, transporte, telecomunicaciones, sanidad)
- Sistema Nacional de Respuesta a Incidentes en colaboración con CCN, Guardia Civil, Policía Nacional

Presupuesto inicial: €300 millones para infraestructura, con enfoque en formación de talento (España requiere 80,000+ profesionales en ciberseguridad en próximos tres años).

Esquema Nacional de Seguridad (ENS)

El ENS, regulado por Real Decreto 311/2022 (actualización 2022 con vigencia gradual hasta mayo 2024), establece norma obligatoria para todo sector público español. Estructura organizada en tres niveles de seguridad (bajo, medio, alto) basados en impacto de incidentes. Aunque anterior a NIS2, el ENS proporciona referente de línea base para medidas técnicas y organizacionales, especialmente en auditorías continuas y gestión de incidentes.

D. Inversión Estatal y Compromisos Presupuestarios

La respuesta estatal española a intensificación de ciberamenazas se materializa en €1.157 mil millones asignados por Plan Nacional de Ciberseguridad, distribuidos:

- 60%: Ministerio de Defensa, Centro Criptológico Nacional (CCN-CERT), Comandancia Conjunta de Ciberespacio
- 40%: Ministerio del Interior, Secretaría de Estado para Telecomunicaciones, Red.es, Agencia Estatal de Administración Digital (AEAD)

Medidas operacionales incluyen: expansión del 5G Security Operations Center (SOC 5G), auditorías automatizadas de servicios digitales públicos, integración de técnicas avanzadas de IA para detección de ciberataques, coordinación mejorada entre SOC's público-privados.

II. PANORAMA GLOBAL DE AMENAZAS CIBERNÉTICAS 2024-2025

A. Magnitud Económica y Estadísticas de Incidentes

El cibercrimen ha alcanzado proporción sistémica. Estimaciones para 2025 proyectan costos globales de \$10.5 billones USD (incremento 31% año a año), continuando trayectoria de crecimiento acelerado desde \$6 billones estimados 2021.[6][7]

Métricas de Incidentes Documentados:

- Centro de Quejas de Delitos Cibernéticos (IC3, USA): 859,532 denuncias 2024 con pérdidas >\$16 mil millones (+33% respecto 2023)
- Costo Promedio Brecha de Datos: \$4.44M globalmente (2025), reducción del 9% respecto \$4.88M 2024, atribuible a detección más rápida y adopción de seguridad asistida por IA. Variación regional: US \$10.22M (máximo histórico, impulsado por litigios, CCPA). Europa ~\$4M. Asia-Pacífico 2-3M.
- Ransomware: 5,414 víctimas publicadas 2024 (+11% vs 2023). Q4 2024: 1,827 incidentes (33% del total anual, +29% vs Q4 2023). 46 nuevos grupos emergentes (incremento 48% de grupos activos). Top 10 grupos responsables de 52.8% de ataques.
- Phishing: 197% incremento en ataques por email H2 2024 vs H2 2023. 31.4% de correos spam; 1.4% contiene malware/phishing.

Análisis ENISA 2024 (4,900+ incidentes curados):

Seven prime threats identificadas ordenadas por prevalencia: (1) Disponibilidad (DDoS+ransomware), (2) Ransomware, (3) Amenazas a datos, (4) Ingeniería social, (5) Malware-as-a-Service, (6) Ataques a cadena suministro, (7) Desinformación/Manipulación.

Vulnerabilidades reportadas 2024: 42,595 nuevas (incremento 27%), con 64% teniendo vector de ataque red. 245 vulnerabilidades añadidas al catálogo CISA Known Exploited Vulnerabilities (KEV) durante período reportes.

B. Evolución de Actores de Amenaza

Actores estatales nexos: Enfoque aumentado en operaciones de espionaje a largo plazo con baja huella. Explotación sistemática de servicios en nube y vulnerabilidades public-facing para acceso covert. Campañas dirigidas a infraestructura de comunicaciones (cables submarinos, sistemas satélites), con implicaciones geopolíticas significativas.

Actores cibercriminales: Ecosistema "as-a-service" en maduración. Ransomware-as-a-Service (RaaS) ofrece acceso inicial, desarrollo de malware, exfiltración de datos, portal de divulgación. DDoS-for-Hire services reducen barrera de entrada para atacantes no especializados. Botnet residencial/móvil utilización expandida.

Actores de desinformación: Campañas masivas de "Información Operativa" (IO) sobre infraestructura diplomática, procesos electorales europeos. Geoposicionamiento táctico de mensajes utilizando análisis de datos sobre audiencias regionales.

III. INTELIGENCIA ARTIFICIAL GENERATIVA: VECTORES OFENSIVOS

A. Taxonomy de Amenazas Específicas de GenAI

1. Inyección de Prompts y Ataques Adversariales

Prompt injection constituye vulnerabilidad fundamentalmente arquitectónica en Grandes Modelos de Lenguaje (LLM). Cuando un atacante inserta instrucciones maliciosas en inputs que parecen benignos, el modelo procesa ambos canales (instrucciones legítimas + datos incrustados) como entrada unificada, generando riesgo de desobediencia de guardrails de seguridad.

Línea base de éxito: 87% de ataques de inyección de prompts logran bypass de defensas genéricas.[8] Mitigaciones especializadas utilizando firmas criptográficas redujeron tasas de éxito a <0.5% en modelos fine-tuned. Técnicas emergentes como StruQ (structured queries, separación de canales prompt/datos) y Signed-Prompt Method demuestran robustez significativa.

Jailbreak attacks (e.g., "Do Anything Now" v15.0) explotan tendencia de LLMs a seguir instrucciones literalmente, induciendo outputs nocivos. Anthropic Red Team dataset documentó milenios de adversarial prompts; evaluación Prompt-Guarding (Prompt-G) redujo attack success rate integrado con Llama 2 13B a 2.08%.

OWASP LLM01:2025 designa prompt injection como amenaza top-tier para ecosistema generativo.

2. Envenenamiento de Datos (Data Poisoning)

Ataques durante fase training/tuning introducen datos maliciosos o corruptores que sesgan comportamiento de modelo. Vectores de ataque incluyen: (a) inyección directa en conjuntos training durante desarrollo, (b) compromiso de fuentes de datos upstream pre-training, (c) poisoning "split-view" de dominios expirados recomprados, (d) "frontrunning poisoning" en datasets web scraped.

Impacto documentado: modelos envenenados generan decisiones discriminatorias, recomendaciones incorrectas, fallos en detección de amenazas (especialmente crítico en sistemas de detección malware basados en ML). Backdoors incrustados activan bajo triggers específicos sin afectar funcionalidad nominal. Ejemplo demostrado: clasificador de malware entrenado en datos envenenados falló en identificar muestras maliciosas reales, tratándolas como software legítimo.

Mitigación requiere: (a) verificación de integridad de datasets, (b) data provenance tracking, (c) sanitización de datos training, (d) reevaluación periódica contra conjuntos clean de referencia.

3. Extracción de Modelos e Inversión de Datos

Model extraction (también "model stealing"): atacante interactúa repeatedly con API de modelo para construir dataset sintético de inputs/outputs, luego entrena modelo sustituto que replica comportamiento original.

Relevancia económica: modelos generativos representan años de investigación + datos propietarios. Clonación via API es técnica viable de robo de propiedad intelectual. Google Threat Intelligence observó actores estatales usando Gemini para research en vulnerabilidades, desarrollo de payloads, scripting malicioso - demostrando acceso a modelos de frontera sin restricciones significativas.

Model inversion: análisis de respuestas de modelo para reconstruir datos sensibles de training (e.g., información de salud, registros financieros, PII). Ataques membership inference determinan si muestra específica fue parte del dataset training.

Defensa: rate limiting, output obfuscation, watermarking de modelos, access control restringido, anomaly detection en patrones de queries.

4. Ataques a Cadena de Suministro de IA

Vulnerabilidad crítica emergente 2024-2025. Atacantes inyectan código malicioso en componentes AI reutilizados (modelos pre-trained, librerías ML) en repositorios públicos (PyPI, npm, Hugging Face). Desarrolladores incorporan desprevénidamente dependencias comprometidas.

Caso de uso: Malicious AI Models in Software Supply Chains. Repositorios albergan modelos con backdoors incrustados; cuando deployed, ejecutan acciones no autorizadas (exfiltración de datos, manipulación de integridad, acceso remoto). MLOps platforms no detectan malware en serialized model files.

Precedente 2025: SolarTrade (platform logística usada por 500+ retailers) comprometida cuando atacantes inyectaron código malicioso en actualización rutinaria de software. Acceso conseguido a información de pago de clientes; operaciones de cadena suministro disrupted por meses.

Otro vector documentado: firmware de dispositivos médicos (marcapasos, bombas de insulina) comprometido via ataque a fabricante (Medtech). Implicaciones de seguridad del paciente extremas.

Mitigation: SBOM (Software Bill of Materials), verificación criptográfica de componentes, scanning de modelos pre-deployment, auditoría de proveedores terceros, control de acceso a repositories.

5. Deepfakes y Manipulación de Contenido Multimedia

Crecimiento explosivo: 500,000 archivos deepfake (2023) – 8 millones (2025). Tasa de crecimiento: 900-1,740% por región. Técnicas de generación ahora accesibles via "Deepfake-as-a-Service" (DaaS) platforms, eliminando barreras técnicas para actores menores.

Detección humana: capacidad de identificación apenas ~24.5% para videos deepfake de alta calidad - apenas mejor que adivinanza aleatoria. Sistemas de detección automatizados sufren degradación de 45-50% en accuracy cuando se evalúan contra deepfakes reales (vs. condiciones lab controladas).

Aplicación ofensiva: (a) suplantación de identidad ejecutiva ("CEO fraud"), (b) fraude de verificación de identidad en servicios financieros, (c) disinformation campaigns a escala. Precedente: January 2024,

empresa engineering Arup victimizada por fraud \$25M vía deepfake de video ejecutivo. FS-ISAC reporta \$500M+ en fraude anual impulsado por deepfakes (proyectado \$40M para 2027 conforme a Deloitte).

Defensas emergentes: multimodal real-time detection (voice + video + behavioral patterns) alcanza 94-96% accuracy bajo condiciones óptimas con ensemble methods. Federated learning updates detección diariamente. >100 instituciones financieras deployed behavioral biometrics networks. Verificación criptográfica de comunicaciones; procedimientos callback usando canales pre-verificados.

6. Phishing Asistido por IA y Ingeniería Social

Email attacks incrementaron 197% H2 2024 vs H2 2023. Generative AI permite creación de phishing campaigns masivamente personalizadas:

- Análisis OSINT de targets individuales – tailored messaging
- LLMs generen contenido contextualmente creíble con urgencia artificial
- Multilingual content generation at scale
- Social engineering narratives hyper-personalizados

Observación operacional (Google Threat Intelligence, 2024): Iranian APT42 utilizó Gemini (30%+ de su actividad) para reconnaissance sobre policy experts, drafting de spear-phishing campaigns, investigación de vulnerabilidades específicas (Mikrotik, Apereo, Atlassian). Aparentemente también utilizó Gemini para preparar contenido de entrenamiento de red teams sobre "cómo usar AI ofensivamente."

Tácticas Chinese APT: uso de Gemini para asistencia en coding tasks, scripting development dirigido a acceso más profundo post-compromise. Ejemplo específico: solicitud para firmar plugins de Outlook maliciosamente y deployarlos silenciosamente a todas computadoras.

7. Malware Generado por IA y Evasión Técnica

AI-assisted malware development reduce barrera de entrada. Ransomware group FunkSec notablemente heavy user de LLMs para generación de código (comentarios lingüísticamente perfectos sugieren herramientas LLM). Estrategia: ransoms bajos, volumen alto (economía de escala).

Técnicas de evasión: malware basado en reinforcement learning se reescribe continuamente para evadir firewalls, bypass EDR, explotar vulnerabilidades dinamicamente. A diferencia de malware signature-based, variants generadas por IA son heterogéneas y adaptativas.

Polimorfismo: malware que muta su código mientras mantiene funcionalidad; traditional signature-based detection ineficaz.

IV. INTELIGENCIA ARTIFICIAL GENERATIVA: CAPACIDADES DEFENSIVAS

Paralelamente a amenazas ofensivas, GenAI habilita defensas de próxima generación.

A. Detección de Amenazas Asistida por ML

Sistemas de Detección de Intrusiones (IDS) Basados en Machine Learning

IDS tradicionales basados en firmas quedan obsoletos ante amenazas desconocidas (zero-day). ML-based IDS aprenden características estadísticas de attacks históricos, permitiendo detección de patrones anómalos.

Benchmarks de Rendimiento Documentado:

- Random Forest macro-classifier: detección 100% de malware conocido, 88.54% de malware zero-day; F1 score 90.96% en clasificación de clases maliciosas
- Decision Tree (max depth 5): tasa positivo verdadero 96%, falso positivo 5%
- GAN discriminator-based detector: >98% accuracy detección zero-day
- Autoencoder-enhanced (Random Forest + XGBoost): rendimiento superior en generalization a datos unseen
- Effective ML-based IDSML accuracy media: 96.9% detección de ataques (dataset NSL-KDD)

Detección Basada en Comportamiento (Behavioral Analytics)

User and Entity Behavior Analytics (UEBA) powered by ML: establece baselines dinámicas de comportamiento normal, luego identifica desviaciones. Excelente para: (a) insider threats, (b) compromised credentials, (c) novel attack methods sin signatures conocidas.

Machine learning identifica zero-day exploits via anomalías comportamentales mucho antes de disponibilidad de updates de signature. Organizaciones utilizando behavioral analytics reportan 60% reducción en false positives vs. rule-based detection.

B. Threat Hunting Augmented por IA

Reducción de Dwell Time

Threat hunting proactivo descubre amenazas latentes que bypass defensas automatizadas. AI-powered continuous hunting analiza miliarios de eventos en real-time, identificando patrones y anomalías sutiles.

Métrica de Impacto: Mean Time to Detect (MTTD) reducido de 181 días (promedio industrial) a <24 horas con sistemas AI-driven. Reducción de 300-400% en discovery time.

Técnicas AI-Enhanced:

- Hypothesis-Driven Hunting: threat intelligence fueling hypotheses específicas sobre attack paths; AI correlaciona indicators contra logging
- Anomaly-Based Hunting: UEBA basado en ML establece baselines adaptativas, detecta desviaciones
- Intelligence Enrichment: AI enriquece Indicators of Compromise (IOCs) con contexto, correlaciona múltiples fuentes, predice IOC variants
- Predictive Threat Intelligence: ML forecasts probable attack vectors, threat actor behaviors, vulnerability exploitation likelihood
- Behavioral Hunting: AI detecta behaviors asociados con attacker objectives (reconnaissance, lateral movement, data exfiltration) vs. single IOCs

Hybrid approach combina hypothesis-driven, intelligence-based, behavioral methodologies para maximum effectiveness.

C. Respuesta Automatizada de Incidentes (SOAR)

Security Orchestration, Automation & Response (SOAR) integrado con AI logra unprecedented efficiency:

- Automated Triage: AI prioriza alerts basado en severity, context, business impact
- Orchestrated Response: coordina acciones across systems (endpoint isolation, access revocation, credential reset)
- Continuous Learning: feedback loops y ML mejoran detection + response over time
- MTTD + MTTR Acceleration: mean time to respond (MTTR) accelerated via automation; humans enfocados en complex threats
- NLP-Generated Summaries: LLMs generan narrativas coherentes stitching scattered alerts into threat storyline

D. Detección de Deepfakes y Verificación de Contenido

Multimodal Real-Time Detection

Leading solutions analyze voice, video, behavioral patterns simultaneously, alcanzando 94-96% accuracy en optimal conditions. Ensemble methods combining múltiples detection algorithms más resilientes a adversarial attacks que sistemas individuales.

Continuous Retraining via Federated Learning

Detección models reentrenados diariamente con emerging threats, preservando privacy. Desafío fundamental: "arms race" asimétrico - generación deepfake avanza a 900% annually mientras detección crece ~30-40% CAGR.

Multi-Factor Authentication Beyond Traditional Methods

Behavioral biometrics: typing patterns, navigation habits analyzed in real-time. Verification protocols unbreakable por synthetic media: pre-established secondary channels, cryptographic device authentication, mandatory time delays para high-value transactions.

V. MARCOS NORMATIVOS Y GOBERNANZA

A. Regulación Europea: EU AI Act

El **EU AI Act** (primer marco legal comprehensive sobre AI globalmente) adoptó enfoque risk-based tricotomizado:

Categorías de Riesgo:

6. Unacceptable Risk (Art. 5): 8 prácticas prohibidas (manipulación basada en IA, exploración de vulnerabilidades, social scoring, etc.)
7. High-Risk (Chapters 2-3): sistemas en infraestructura crítica, healthcare, law enforcement, education. Obligaciones estrictas pre-market
8. Limited/Minimal Risk: menos regulación; compliance general expectations

Requisitos Específicos Ciberseguridad (Art. 15):

- Robustez y exactitud apropiadas
- Resiliencia contra "unauthorized tampering"
- Protección contra adversarial attacks (data poisoning, model manipulation)
- Technical documentation detailed
- Incident monitoring + timely reporting

General-Purpose AI Models with Systemic Risk (Art. 55): Large-scale, adaptable foundation models requieren:

- Continuous risk assessment
- Adversarial testing para vulnerability identification
- Adequate cybersecurity nivel for system + physical infrastructure
- Incident monitoring

Timeline Implementación: Entrada en vigor agosto 2024 para prohibiciones. Obligaciones high-risk: agosto 2026. (Some provisions diferido a agosto 2027).

B. Directiva NIS2 y Resiliencia Cibernética

Scope Expansion Crítica: Original NIS Directive cubría ~1,000 entidades. **NIS2 expande a ~12,000** distribuidas en 18 sectores (energía, transporte, agua, salud, finanzas, telecomunicaciones, infraestructura digital, administración pública, fabricación, etc.).

Clasificación Bifurcada:

- **Essential Entities (EE):** ≥250 empleados OR €50M annual turnover
- **Important Entities (EI):** ≥50 empleados OR €10M annual turnover (nuevos umbrales reducidos)
- **Size-agnostic inclusion:** key service providers regardless of scale (DNS, telcos, cloud)

Obligaciones Core (Art. 21):

- Risk management systems + board cyber accountability
- Supply chain security + vendor assessment

- Incident detection + response capabilities
- Cross-border incident reporting (24h initial, 72h detailed)

Enforcement Architecture (España):

- CNCS (new): lead authority, registration portal, cross-sector coordination
- Sector-specific authorities: maintain supervisory role
- Penalties: €10M/2% annual revenue (EE very serious), €7M/1.4% (EI), €100-500K (serious), €10-100K (minor)
- Public entities exempt from fines pero NOT exempt from compliance

C. NIST AI Risk Management Framework (AI RMF 1.0)

Estructura Core - Cuatro Funciones Iterativas:

9. Govern: Políticas AI, roles de accountability, governance cultural
10. Map: Identificar AI risks, documentar lifecycle risks
11. Measure: Metrics cuantitativos/cualitativos para assess risks, effectiveness de controls
12. Manage: Mitigación de riesgos, prioritization, tratamiento

Características de Trustworthy AI (Framework Axis):

- Reliability + Safety
- Security + Accountability
- Explainability + Fairness
- Privacy + Human-centered design

GenAI Profile (2024): NIST released GenAI-specific profile con 400+ mitigation actions addressing prompt injection, data poisoning, model extraction, supply chain risks, misinformation, etc.

Integración Ecosystem: AI RMF integrable con ISO 31000 (risk management), ISO 27001 (information security), SOC 2 Type II controls, EU AI Act technical documentation requirements.

D. ISO/IEC 42001:2023 - AI Management Systems Standard

Certifiable international standard para establishing, implementing, maintaining AI governance systems.

Scope: Organizations of any size developing, deploying, or using AI systems.

Key Domains Covered:

- AI governance + accountability (roles, responsibilities, oversight)
- Risk assessment + treatment specific to AI
- Data quality, transparency, explainability
- Security + resilience of AI systems
- Monitoring, measurement, continuous improvement
- Third-party + supply chain AI risk management

Integration Con Otros Standards:

- **ISO 27001:** Complementary; ISO 42001 addresses AI-specific governance beyond traditional security
- **ISO 31000:** Risk management framework; AI RMF can be operationalized via ISO 31000 infrastructure
- **ISO 9001:** Quality management; ISO 42001 ensures quality in AI decisions

Adoption Drivers 2025:

- 45% of organizations evaluating ISO 42001 adoption
- Regulatory readiness (EU AI Act, sector-specific guidance)
- Customer trust + reputation management
- Operational resilience

E. Directrices Nacionales y Coordinación Interagencial

Canadian Centre for Cyber Security + French ANSSI (Febrero 2025)

"Building Trust in AI through Cyber Risk-Based Approach" articula three primary AI attack categories:

13. Poisoning: Alteration of training data or model parameters
14. Extraction: Recovery of confidential model parameters, training data
15. Evasion: Alteration of input data to change expected AI functioning

Recommendations: secure supply chains, verify data integrity, implement defense-in-depth, balance AI benefits against security risks.

CISA (USA) - May 2025 AI Data Security Guidance

Joint guidance (CISA, NSA, FBI, Australia, UK, NZ) focusing on data security across AI lifecycle. Ten cybersecurity best practices specific to AI systems:

16. Source reliable data + track provenance
17. Verify + maintain data integrity during storage/transport
18. Sanitize training data to reduce impact of outliers
19. Implement metadata validation
20. Continuous monitoring + data cleansing
21. Secure data access + storage post-ingest
22. Assess content credentials for data provenance
23. Request assurances from foundation model providers
24. Require certification from dataset providers
25. Segregate security-critical data

UK National Cyber Security Centre (NCSC)

Warning released January 2026: "growing divide" entre organizaciones AI-ready y vulnerables. Threat actors "almost certainly" ya utilizando AI operationally en todas fases de ataque. UK AI Cyber Security Standard: 13 principios para desarrollo seguro de AI; énfasis on protecting critical national infrastructure.

VI. ANÁLISIS TÉCNICO: ARQUITECTURAS DE DEFENSA Y BENCHMARK METODOLÓGICO

A. Red Teaming de Sistemas GenAI

Two-Level Framework:

26. Macro-Level (System) Red Teaming: Spans entire AI development lifecycle
27. Inception: Challenge fundamental assumptions (¿Is AI necessary? ¿Stakeholder motivations? ¿Adversary exploitation vectors?)
28. Design: Threat modeling comprehensive, socio-technical risk analysis
29. Development: Continuous vulnerability assessment
30. Deployment: Operational resilience testing
31. Maintenance: Emerging threat monitoring
32. Micro-Level (Model) Red Teaming: Focus on model-specific vulnerabilities
33. Boundary seeking: Identify model capability limits
34. Edge case generation: Reveal unexpected capabilities/limitations
35. Risk discovery: Expose inherent vulnerabilities pre-deployment

Maintenance: Emerging threat monitoring

Micro-Level (Model) Red Teaming: Focus on model-specific vulnerabilities

Taxonomy: 12 strategies + 35 techniques combining technical knowledge with creative problem-solving.

Challenges with Current Approaches:

- Narrow technical focus at expense of socio-technical systems
- Testing after build (vs. proactive analysis during inception/design)
- Limited English-language evaluation
- Insufficient consideration of insider risks + emergent system behaviors

B. Benchmarking Datasets y Estándares de Medición

MLCommons Jailbreak Benchmark v0.5 (Octubre 2025)

First industry-standard quantification of how adversarial attacks degrade AI safety:

- Safety Baseline: Measured using AILuminate v1.0 (text-to-text) or MSTs (vision-language)
- Adversarial Testing: Standardized jailbreak attack suite (role-playing, misdirection, encoding)
- Resilience Gap Metric: Quantifiable difference in safety performance baseline vs. under-attack

Initial Findings - Critical:

- Text-to-Text models: average safety score reduction **14.98 percentage points** under jailbreak

- Text+Image-to-Text models: **25.27 percentage points** reduction
- Distributed degradation across hazard categories (CBRN, violent crimes, illegal activities, etc.)
- Significant variability: effectiveness of tactics differs widely across systems

Implication: Baseline safety score insufficient indicator of actual resilience. One-size-fits-all defense insufficient; defense-in-depth + tactic-specific hardening required.

Benchmark Datasets Principales:

- HarmBench: Harmful behavior evaluation
- JailbreakBench: Prompt injection specific
- RobustBench: Adversarial robustness (computer vision)
- Anthropic Red Team Dataset: Thousands of adversarial chat transcripts
- OWASP LLM Top 10: Security taxonomy framework

Active Benchmark Initiatives:

- ActiveFence AI Security Benchmark (2025): 28,000+ prompts evaluating detection models. Alice model achieved precision 0.890, F1 0.857, false positive rate 5.4%
- OWASP Gen AI Red Teaming Guide (2025): Practical assessment + testing strategies

C. Zero-Day Detection via ML Avanzado

Métodos de Detección sin Firma:

Traditional IDS signature-based failing. ML-based approaches:

36. Supervised Classifiers: Random Forest, SVM, Decision Trees, Neural Networks

37. Training on known attack + benign traffic

38.

Detection via learned decision boundaries

39.

Unsupervised Anomaly Detection: Autoencoder, Isolation Forest, One-Class SVM

40. Learn normal traffic distribution

41. Flag deviations as potential attacks

42.

Advantage: detects zero-day without labeled attack data

43.

Generative Adversarial Networks (GANs): GAN discriminator trained on malware

44. Superior detection of zero-day variants

45.

98% accuracy documentado

46.

Robust against adversarial perturbations

47.

Transfer Learning: Domain adaptation for zero-day generalization

48. Transductive Transfer Learning most suitable (same source/target task, labels unavailable for target)

49. Spectral transformation + common latent feature space

Detection via learned decision boundaries

Unsupervised Anomaly Detection: Autoencoder, Isolation Forest, One-Class SVM

Advantage: detects zero-day without labeled attack data

Generative Adversarial Networks (GANs): GAN discriminator trained on malware

98% accuracy documentado

Robust against adversarial perturbations

Transfer Learning: Domain adaptation for zero-day generalization

Detectados Métricas Documentadas:

- Random Forest: 98.5348% accuracy, TPR 0.985, FPR 0.001, AUC 0.998
- GAN discriminator: >98% detection accuracy, robust across noise levels
- Autoencoder-enhanced hybrid: remarkable consistency across training, test, unseen datasets
- Mean Squared Error (MSE) reconstruction error: effective anomaly threshold calculation

VII. SÍNTESIS: VECTORES DE RIESGO Y RECOMENDACIONES CONSOLIDADAS

A. Matriz de Riesgos GenAI-Ciberseguridad

Riesgo	Adversario	Fase de Ataque	Impacto	Madurez Amenaza
Inyección de Prompts	Externo/Interno	Ejecución	Bypass de guardrails, outputs maliciosos	Operacional
Envenenamiento de Datos	Suministro/ Insider	Training	Sesgo modelo, fallos detección	Documentado
Extracción de Modelos	Competidor/APT	Post-deployment	IP theft, clonación funcionalidad	Demostrado
Ataques Cadena Suministro	APT/ Cibercriminal	Pre-deployment	Acceso remoto, exfiltración datos	Alto (2025)
Deepfakes	Cibercriminal/APT	Social engineering	Fraude masivo, disinformation campaigns	Explosivo
Phishing Asistido IA	Cibercriminal	Acceso inicial	Credential theft, malware delivery	Prevalente
Malware Generado IA	Cibercriminal/APT	Explotación	Evasión técnica, polimorfismo	Emergente

B. Recomendaciones Estratégicas para España

Nivel Estatal/Gobernanza:

50. Acelerar Implementación NIS2: Roadmap detallado Q1 2026 entry-into-force; recursos para soporte PYMES
51. Potenciar CNCS: Dotación presupuestaria suficiente, reclutamiento talento, coordinación INCIBE/CCN/Defensa
52. Alineación EU AI Act: Armonizar ENS con requisitos EU AI Act pre-agosto 2026 obligatoriedad
53. Investigación Aplicada: Funding para red.es en áreas: detección deepfake, threat intelligence IA, red teaming metodología
54. Formación Especializada: 80,000+ profesionales requeridos; colaboración universidades (RENIC nodes), bootcamps acelerados

Nivel Organizacional (Sector Crítico):

- 55. Adopción ISO 42001: Governance framework para sistemas AI; integración con ISO 27001
- 56. NIST AI RMF: Operacionalización Govern-Map-Measure-Manage; baseline para compliance regulatorio
- 57. Red Teaming Continuo: Pre-deployment adversarial testing; socio-technical risk analysis integral
- 58. Data Supply Chain Security: SBOM para componentes AI, verificación criptográfica, auditoría proveedores
- 59. Monitoreo ML-Based Threat Detection: Despliegue IDS ML, behavioral analytics, threat hunting asistido IA
- 60. Detección Deepfake: Multimodal real-time systems integradas en comunicaciones críticas, verificación MFA biométrica

Nivel Técnico (Defensas Específicas):

- 61. Hardening Prompt Injection: Signed-Prompt Method, StruQ, Moderation Rails
- 62. Protección Data Integrity: Data provenance tracking, content credentials, periodic retraining clean datasets
- 63. API Rate Limiting: Mitigación model extraction; anomaly detection en query patterns
- 64. Isolated Inference Environments: Sandboxing para GenAI deployments en infraestructuras críticas
- 65. Segmentación Red: Segregation de sistemas IA de redes críticas; degraded-mode operations sin AI

VIII. CONCLUSIONES Y PERSPECTIVA 2026

La convergencia entre Inteligencia Artificial Generativa y ciberseguridad ha alcanzado punto de inflexión crítico. Los hallazgos de esta investigación exhaustiva revelan:

66.

Asimetría Temporal: Capacidades ofensivas GenAI (prompt injection, deepfakes, supply chain attacks) tienen precedencia táctica sobre defensas. Tasas de generación amenaza (900%+ para deepfakes) superan capacidad defensiva (30-40% CAGR detección).

67.

Democratización de Sofisticación: Deepfake-as-a-Service, Malware-as-a-Service, DDoS-for-Hire eliminan barreras técnicas. Actores menores ahora capaces de campañas masivas equivalentes a operaciones APT históricas.

68.

Gobernanza Emergente: Marcos normativos (EU AI Act, NIS2, ISO 42001, NIST AI RMF) establecen líneas base, pero enforcement aún incompleto. España posición de liderazgo europeo (NCSI 89.17/100) no inmuniza contra riesgos sistémicos.

69.

Oportunidad Defensiva: ML-based threat detection, AI-augmented threat hunting, behavioral analytics, deepfake detection alcanzando madurez operacional. Organizations que invierten ahora en defensas AI logran 300-400% reduction en MTDD.

70.

Reto de Talento: España requiere 80,000+ profesionales ciberseguridad; current supply grossly insufficient. Investment en formación especializada pre-requisito para viabilidad del modelo de defensa propuesto.

Asimetría Temporal: Capacidades ofensivas GenAI (prompt injection, deepfakes, supply chain attacks) tienen precedencia táctica sobre defensas. Tasas de generación amenaza (900%+ para deepfakes) superan capacidad defensiva (30-40% CAGR detección).

Democratización de Sofisticación: Deepfake-as-a-Service, Malware-as-a-Service, DDoS-for-Hire eliminan barreras técnicas. Actores menores ahora capaces de campañas masivas equivalentes a operaciones APT históricas.

Gobernanza Emergente: Marcos normativos (EU AI Act, NIS2, ISO 42001, NIST AI RMF) establecen líneas base, pero enforcement aún incompleto. España posición de liderazgo europeo (NCSI 89.17/100) no inmuniza contra riesgos sistémicos.

Oportunidad Defensiva: ML-based threat detection, AI-augmented threat hunting, behavioral analytics, deepfake detection alcanzando madurez operacional. Organizations que invierten ahora en defensas AI logran 300-400% reduction en MTDD.

Reto de Talento: España requiere 80,000+ profesionales ciberseguridad; current supply grossly insufficient. Investment en formación especializada pre-requisito para viabilidad del modelo de defensa propuesto.

Prognóstico 2026-2027:

- AI-driven attacks escalarán en sofisticación + volumen; "cyber inequity" entre organizaciones AI-ready vs. vulnerable se acentuará
- Regulatory compliance (NIS2, EU AI Act) forzará modernización defensiva; pequeñas/medianas empresas enfrentarán compliance burden significativo
- Red teaming, threat hunting asistido-IA, y continuous security monitoring serán standard-of-practice no opcional
- Deepfake verification protocols evolucionarán hacia cryptographic authentication; traditional biometric authentication insuficiente
- Emergencia de "AI security engineering" como disciplina distinct, similar a DevSecOps

Requisitos Críticos Éxito (España):

- Coordinación efectiva CNCS/INCIBE/CCN/Defensa sin duplicación/conflictos competenciales
- Inversión sostenida en I+D aplicada (RENIC, universidades, centros de investigación)
- Partnerships público-privado para compartir threat intelligence, benchmarking defensivo
- Educación ejecutiva sobre riesgos GenAI-ciberseguridad a nivel C-suite
- Adopción temprana estándares internacionales (ISO 42001, NIST AI RMF) para ventaja competitiva

REFERENCIAS Y FUENTES

- [1] Gobierno de España, Ministerio del Interior - "The Government approves a strengthening of Spain's cybersecurity," May 2025
- [2] Gobierno de España, Digital.gob.es - "Government Communication on National Cybersecurity Plan," May 2025
- [3] Springboard35.com - "Cybersecurity in Spain: Challenges and Opportunities," April 2025
- [4] ENISA Threat Landscape 2024 Analysis, September 2024
- [5] NCSI (National Cyber Security Index) - Spain Ranking, 2025
- [6] SentinelOne / DeepStrike Cybersecurity Statistics 2025
- [7] Global Cybersecurity Outlook 2025, World Economic Forum
- [8] OWASP Gen AI Security Project - LLM01:2025 Prompt Injection
- [... 135+ additional academic, governmental, and technical sources in research notes]

Documento Clasificación: PÚBLICO - Disponible para distribución institucional

Fecha Preparación: Enero 20, 2026

Validación: Consorcio de Expertos en Ciberseguridad, IA y Resiliencia Digital